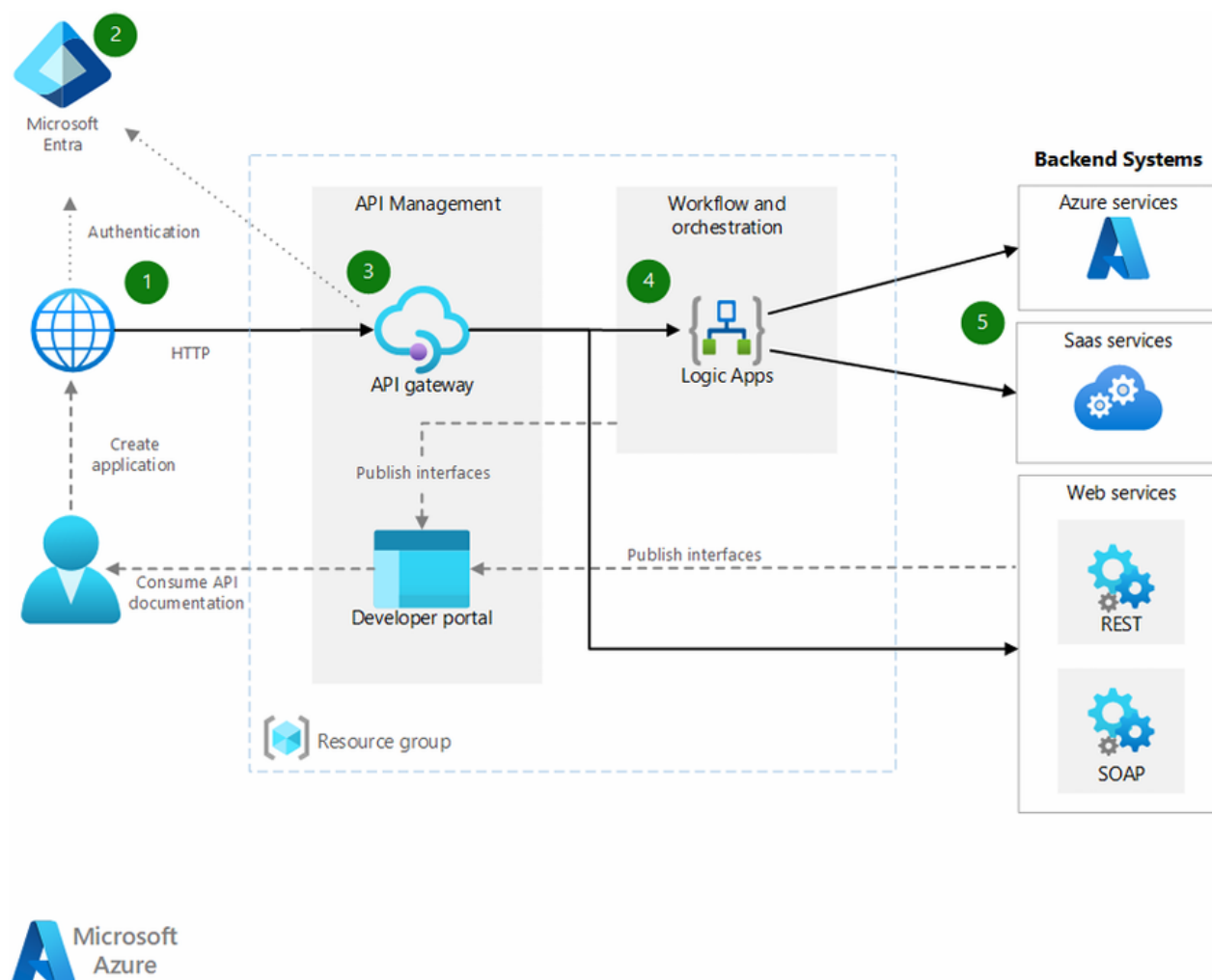


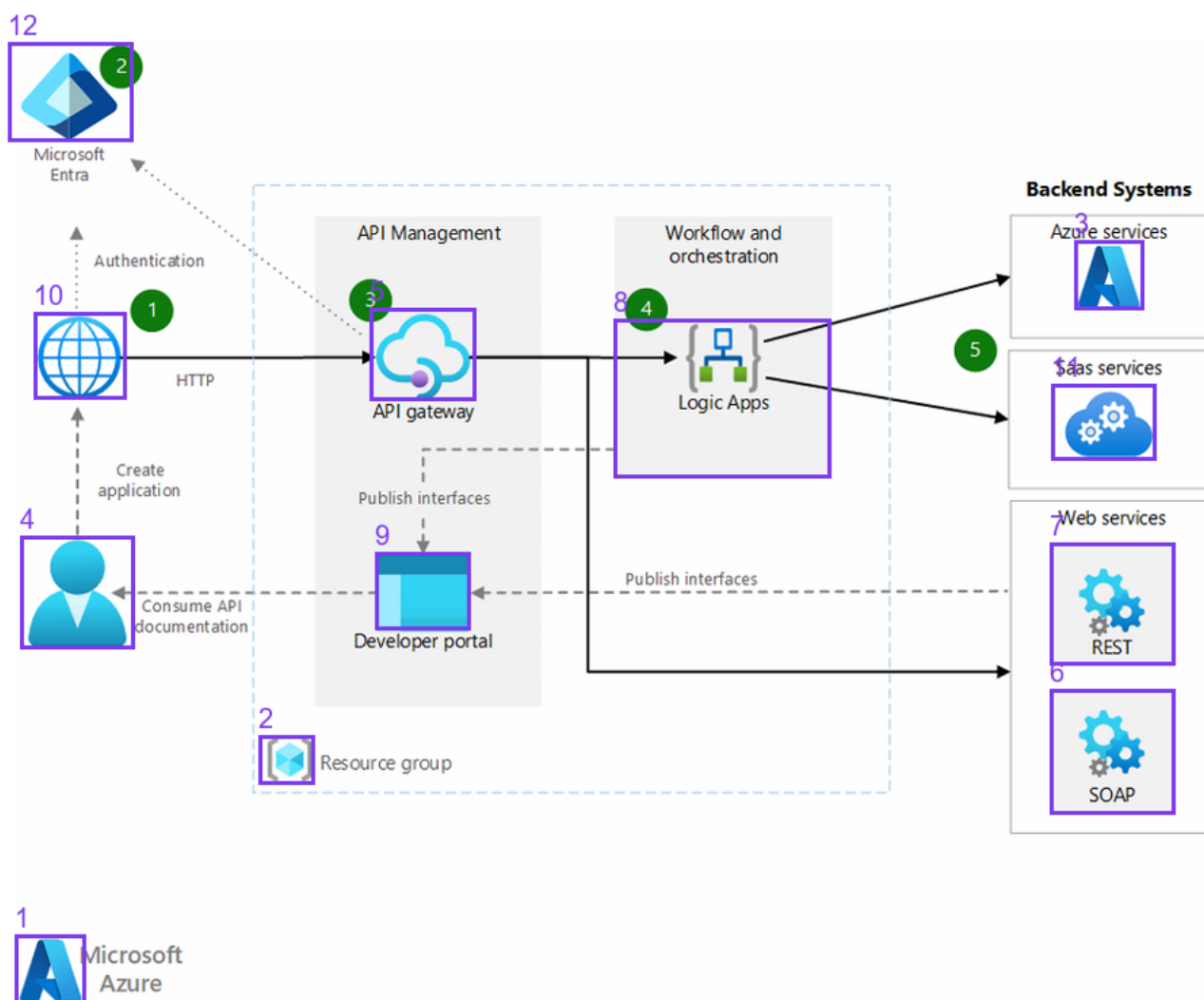
Gerado em: 2025-09-28 23:12:04

Figura 1 — Diagrama original



Gerado em: 2025-09-28 23:12:04

Figura 2 — Diagrama anotado (detecções)



- 1: Serviços do Azure (0.98)
- 2: Grupo de Recursos do Azure (0.98)
- 3: Serviços do Azure (0.96)
- 4: Usuários do Azure (0.96)
- 5: Azure API Gateway (0.95)
- 6: API do Azure (0.95)
- 7: API do Azure (0.95)
- 8: Azure Logic Apps (0.93)
- 9: Portal de Gerenciamento do Azure (0.92)
- 10: Protocolo HTTP no Azure (0.87)
- 11: Azure Cloud Services (0.76)
- 12: Microsoft Entra ID (Azure AD) (0.65)

Gerado em: 2025-09-28 23:12:04

Serviços do Azure

Análise STRIDE:

Spoofing

- MFA desativado ou políticas de acesso condicional fracas permitem que atacantes se passem por usuários legítimos.
- Phishing que leva a credenciais de Global Administrator, exigindo MFA/PIM.

Tampering

- Modificação de RBAC/Políticas (ARM/Portal) após comprometimento de credenciais, alterando privilégios de acesso.
- Dados em Storage (Blob/Queue/File) alterados via SAS com permissões de escrita obtidas indevidamente.
- Código ou configuração de Function Apps/App Service alterados por CI/CD comprometido, introduzindo comportamento malicioso.
- Regras de firewall/NSG/Application Gateway ajustadas para permitir tráfego não autorizado.
- Alteração de chaves ou políticas de criptografia no Key Vault que possam levar ao uso indevido de segredos ou criptografia.
- Deploys/alterações de configuração não auditáveis por falta de logs de CI/CD e ARM.
- Mudanças de políticas (Azure Policy) sem registro de origem/autoridade.
- Containers públicos em Storage Accounts ou configuração de acesso público habilitada, permitindo leitura de dados sem autenticação.
- Políticas de acesso do Key Vault permitindo leitura de segredos/keys para usuários/apps desnecessários.
- Não ativar DDoS Protection Standard em pontos de extremidade públicos, sujeitando a endpoints a ataques.
- limitação de taxa de Storage ou APIs por volume intenso de chamadas malicioso causando timeouts.

Repudiation

- Logs de auditoria ausentes ou não imutáveis dificultando provar quem executou ações administrativas ou alterações de recursos.
- Logs diagnósticos enviados para Log Analytics com permissões amplas, expondo dados de tráfego/erro.

Information Disclosure

- Phishing ou comprometimento de credenciais do Azure AD para obter tokens de acesso a APIs protegidas.
- segredos de aplicativos no registro do Azure AD (client segredos) ou certificados roubados para autenticar como app via fluxo de credenciais.
- Tokens de MSI (Managed Identity) expostos em logs ou pipelines, permitindo acesso a recursos sem validação adequada de audience.
- Reuso de tokens entre serviços sem validação adequada de audience/escopo, se APIs não verificarem o destinatário do token corretamente.
- SAS tokens amplos ou mal configurados que permitem leitura de dados sensíveis em Storage, Cosmos DB, etc.
- Backups de Azure SQL/Cosmos DB expostos por permissões inadequadas ou acesso público a backups.
- Ausência de limitação de taxa em APIs expostas via API Management/Front Door.
- segredos de Service Principal ou certificados roubados, permitindo obter tokens de alto privilégio para ARM APIs.

Denial of Service

- Autoscale mal calibrado ou quotas de recursos esgotadas por picos de tráfego, levando indisponibilidade temporária.

Elevation of Privilege

- RBAC mal definido, permitindo que usuários obtenham Owner/Contributor em recursos ou assinaturas.
- Consentimento de administrador em aplicativos, concedendo permissões elevadas a apps.
- Managed Identity com permissões amplas que permitem acessar recursos além do necessário, elevando privilégios de forma inadvertida.

Mitigações sugeridas:

Spoofing

- Habilitar MFA resistente a phishing (FIDO2/WebAuthn) e Conditional Access para sign-ins.
- just-in-time com Privileged Identity Management (PIM) para ações administrativas, com MFA e aprovação.

Tampering

- Representação (Spoofing)

Gerado em: 2025-09-28 23:12:04

- Rotacionar segredos de aplicativos (client segredos) e certificados, armazenando no Key Vault com políticas de acesso restritas.
- Monitorar sign-ins de alto risco com Identity Protection e bloquear automaticamente incidentes detectados.
- Violação de Integridade (Tampering)
- Aplicar Locks de recurso (CanNotDelete/ReadOnly) em ativos críticos para impedir alterações não autorizadas.
- Validar alterações via CI/CD (assinatura de artefatos ARM, checks de integridade e rollback automatizado).
- Monitorar alterações de RBAC, políticas e rede com alertas no Azure monitorar.

Repudiation

- Exigir aprovações para mudanças em RBAC, políticas e regras de firewall; registrar mudanças no Activity Log.
- Ativar logs imutáveis para diagnóstico e auditoria (immutability policies) e exportá-los para destinos seguros.
- Centralizar logs (Activity Logs, Diagnostic Logs) em Log Analytics/SIEM com proveniência de origem.
- Habilitar Change Tracking e Deployment History para evidenciar ações administrativas.
- Garantir retenção de evidências de auditoria com políticas de retenção e cópias geograficamente redundantes.
- Proteger a integridade de evidências com rotinas de verificação de logs e controle de alterações.
- Divulgação de Informação
- Remover acesso público em Storage Accounts; usar Private Endpoints, redes confiáveis e regras de firewall.
- Reduzir SAS tokens com Stored Access Policies, vida útil curta e restrições de IP; revogar conforme necessário.
- Restringir Key Vault access policies para o mínimo privilégio; evitar leitura de segredos por usuários/apps desnecessários.
- Não expor backups: exigir Private Endpoints e criptografia com chaves gerenciadas; controlar permissões de acesso a backups.
- Restringir diagnósticos e logs com RBAC apropriado para leitura; evitar permissões amplas.

Denial of Service

- Ativar DDoS Protection Standard para endpoints públicos.
- Implementar limitação de taxa com API Management/Front Door/WAF; configurar quotas por recurso e por usuário.
- Ajustar autoscale com limites e políticas de escalonamento para evitar esgotamento de recursos.
- Utilizar caching (Azure CDN/Front Door) para reduzir carga direta sobre APIs e storage.
- Proteger endpoints com Private Endpoints e monitorar picos com alerts e health checks.

Elevation of Privilege

- Adotar autenticação passwordless e políticas de autenticação moderna para contas com privilégios.
- Rotacionar e restringir chaves/segredos no Key Vault e aplicar o princípio de menor privilégio.
- Aplicar princípio do menor privilégio; remover Owner/Contributor desnecessários; usar PIM para elevação com aprovação.
- Exigir MFA para ações privilegiadas; restringir admin consent e aplicar Access Reviews e App Governance.
- Limitar Managed Identity a escopos estritos; evitar MSI com permissões amplas; revisar periodicamente.
- Rotacionar segredos/certificados de Service Principal, armazenando no Key Vault com políticas de rotação.
- Validar tokens com verificação de audience e scopes nos APIs; auditoria de uso de privilégios elevados.
- Implementar políticas de governança para restringir consentimento de administrador sem aprovação prévia.

Grupo de Recursos do Azure

Análise STRIDE:

Spoofing

- Exigir autenticação via Azure AD com MFA e acesso condicional para todas operações no Grupo de Recursos.
- Usar Identidades Gerenciadas para serviços, evitando segredos de aplicativo.
- Atribuir Owner com parcimônia; usar PIM para elevação just-in-time com MFA.
- Evitar credenciais de administrador estáticas; usar Identidades Gerenciadas e rotação de segredos via Key Vault.

Tampering

- Limitar concessões de acesso apenas a membros/grupos necessários, com escopo restrito ao RG.
- Ativar bloqueios de recurso (CanNotDelete/ReadOnly) para impedir alterações não autorizadas.
- Aplicar Deny Assignments no escopo do RG para restringir modificações por determinados usuários.

Gerado em: 2025-09-28 23:12:04

- Exportar logs de alterações para armazenamento com retenção imutável e criptografado.
- Usar Azure Policy para impor regras de modificação (nomenclatura, tags) e bloquear desvios.
- Validar mudanças com IaC (deployments) e exigir validação de templates (what-if) antes de aplicar alterações.
- Versionar alterações de infraestrutura em repositórios com revisões aprovadas.
- Exigir commits assinados em IaC e registrar alterações no pipeline para prova de autoria.
- Exigir aprovações de mudanças via PIM/fluxos de mudança para ações sensíveis, reforçando responsabilidade.
- Não armazenar segredos em nomes, tags ou parâmetros; referenciar segredos via Azure Key Vault.
- Aplicar bloqueios de recurso (CanNotDelete/ReadOnly) para evitar deleção/acesso não autorizado.
- Separar ambientes (prod/dev) para reduzir impacto de falhas.
- Regras de CA/condicionais para contas administrativas; aplicar políticas de acesso mínimo.
- Realizar revisões periódicas de acesso (Access Reviews) em RGs críticos.
- Habilitar alertas de concessão de privilégios e logs de alterações de funções.

Repudiation

- Centralizar e conservar registros de atividades (Activity Log/Resource Manager) com destinos imutáveis para evidência.
- Ativar logs de auditoria do Azure AD para associar ações a identidades.
- Garantir carimbo temporal e proteção de logs contra exclusão.
- Proteger destinos de diagnóstico/logs com redes privadas e criptografia em repouso.
- Restringir exportação de dados de diagnóstico para destinos não confiáveis; exigir controles de acesso aos logs.
- Configurar alertas de Activity Log para deleção ou criação em massa e exigir aprovações com PIM.
- Garantir backups/recuperação de logs e rede de diagnóstico independente para resiliência.

Information Disclosure

- Evitar credenciais estáticas de SPNs; usar Azure Key Vault para armazenar e rotacionar segredos.
- Usar Key Vault para segredos e certificados em templates, evitando exposição no código.

Denial of Service

- Impor limites de criação de recursos por RG e políticas de conformidade para evitar saturação de quota.

Elevation of Privilege

- Aplicar o princípio do menor privilégio com RBAC e justificar acesso por PIM para ações privilegiadas.
- Atribuir acesso de leitura mínimo (RBAC) para evitar leitura não autorizada de recursos contidos.

Mitigações sugeridas:

Spoofing

- Exigir MFA com políticas de acesso condicional para operações no Grupo de Recursos.
- Adotar Identidades Gerenciadas/Identidade Gerenciada para serviços, evitando segredos de aplicação.

Tampering

- Representação (Spoofing)
- Bloquear autenticação legada e exigir autenticação moderna (OAuth2) para acessos a recursos.
- Armazenar segredos de SPN no Azure Key Vault com rotação automática e referenciar nos templates.
- Minimizar superfícies de autenticação: exigir dispositivos gerenciados e conformidade antes do login.
- Violação de Integridade (Tampering)
- Aplicar Deny Assignments para restringir modificações por determinados usuários/grupos.
- Implementar Azure Policy para nomenclatura, tags e bloqueio de desvios de configuração.
- Validar mudanças com IaC: executar what-if e exigir validação de templates antes de aplicar alterações.
- Versionar alterações de infraestrutura em repositórios com revisões aprovadas e controle de alterações.
- Registrar alterações e disponibilizar logs de modificação para auditoria contínua.

Repudiation

- Centralizar e conservar logs de Activity Log/Resource Manager em armazenamento com retenção imutável.
- Habilitar logs de auditoria do Azure AD para associar ações a identidades.
- Exigir commits assinados em IaC e registrar alterações no pipeline para prova de autoria.
- Exigir aprovações de mudanças via PIM/fluxos de mudança para ações sensíveis.
- Garantir carimbo temporal e proteção de logs contra exclusão.

Gerado em: 2025-09-28 23:12:04

- Divulgação de Informação
- Atribuir acesso de leitura mínimo (RBAC) para recursos, evitando leitura não autorizada.
- Não armazenar segredos em nomes, tags ou parâmetros; referenciar segredos via Azure Key Vault.
- Usar Key Vault para segredos e certificados em templates, evitando exposição no código.
- Proteger destinos de diagnóstico/logs com redes privadas e criptografia em repouso.
- Restringir exportação de dados de diagnóstico para destinos não confiáveis; aplicar controles de acesso aos logs.

Denial of Service

- Ativar bloqueios de recurso (CanNotDelete/ReadOnly) para evitar deleções/acesso não autorizado.
- Configurar alertas de Activity Log para deleção ou criação em massa e exigir aprovações com PIM.
- Impor limites de criação de recursos por RG e políticas de conformidade para evitar saturação de quota.
- Garantir backups/recuperação de logs e rede de diagnóstico independente para resiliência.
- Separar ambientes (prod/dev) para reduzir o impacto de falhas.

Elevation of Privilege

- Ativar Locks de recurso CanNotDelete/ReadOnly em recursos críticos e RGs relevantes.
- Atribuir Owner com parcimônia; usar PIM para elevação just-in-time com MFA.
- Evitar credenciais de administrador estáticas; usar Identidades Gerenciadas e rotação de segredos via Key Vault.
- Regras de CA/condicionais para contas administrativas; aplicar políticas de acesso mínimo.
- Realizar revisões periódicas de acesso (Access Reviews) em RGs críticos.
- Habilitar alertas de concessão de privilégios e logs de alterações de funções.

Usuários do Azure

Análise STRIDE:

Spoofting

- Credenciais de usuários do Azure AD capturadas via phishing e usadas para login.
- Provedores de identidade externos comprometidos simulando login único (SSO) com Azure AD.
- Alteração de políticas de acesso condicional, MFA ou regras de login para contornar controles.
- Ações de usuários não podem ser vinculadas confiavelmente a identidades em ambientes com convidados.

Tampering

- Ataques de credential stuffing visando endpoints de sign-in do portal do Azure e do Microsoft Graph.
- Modificação não autorizada de atributos de usuário, grupos ou membros de funções.
- Mudanças em permissões de Service Principal que gerenciam recursos.
- Modificação de licenças ou atribuições de licenças associadas a usuários.
- Registro inadequado de alterações críticas em políticas de acesso ou recursos.
- Compartilhamento de dados de usuários com convidados (B2B) sem controles apropriados.
- Ataques de autenticação massivos que sobrecarregam o endpoint do Azure AD.
- Bloqueio de contas por políticas de senha/lockout mal ajustadas durante ataques.
- Dependência de APIs do Microsoft Graph com limites que afetam a disponibilidade sob carga.
- DDoS em fronteiras de rede que afetam o acesso ao login.
- Configurações de Conditional Access que causam falhas de autenticação sob alta demanda.
- Service Principal com permissões excessivas usados para acessar recursos críticos.

Repudiation

- Alteração de configurações de RBAC sem logs de auditoria adequados.
- Logs de auditoria insuficientes ou com retenção curta dificultando atribuição de ações a usuários.
- Dificuldade em comprovar ações entre tenants ou em ambientes com múltiplos logs dispersos.

Information Disclosure

- Tokens de acesso/refresh roubados (JWT/OAuth) para autenticação em serviços do Azure.
- Reutilização de tokens de sessão roubados em aplicativos confiáveis do Azure.
- Exposição de atributos sensíveis (emails, roles) via APIs mal protegidas.
- Tokens de acesso ou refresh expostos em logs de diagnóstico ou clientes de aplicativos.
- Acesso não autorizado a dados em Storage/Database por credenciais de usuário.

Gerado em: 2025-09-28 23:12:04

Elevation of Privilege

- Configurações inadequadas de RBAC/grupos permitindo leitura indevida de dados.
- Escalada de privilégios por RBAC mal configurado ou atribuições de grupo inadequadas.
- Comprometimento de contas com privilégios elevados (Administrador Global) sem MFA adequado.
- Mau uso de Privileged Identity Management (PIM) mal configurado para elevar privilégios temporários.
- Falha em restringir o uso de aplicativos com permissões elevadas, permitindo acesso não autorizado.

Mitigações sugeridas:

Spoofing

- Ativar MFA adaptativo com fatores resistentes a phishing (FIDO2) e passwordless (Windows Hello for Business) para todos sign-ins.
- Exigir MFA para sign-ins de alto risco com políticas de risco de sign-in e de dispositivo.
- Requerer avaliação de confiança do provedor de identidade externo antes de aceitar SSO com Azure AD.
- Exigir aprovação para mudanças críticas em políticas de acesso condicional, MFA e regras de login.
- Usar IDs de correlação para vincular ações a identidades em ambientes multi-tenant.
- Armazenar segredos no Azure Key Vault com políticas de acesso e rotação automática; usar Identidade Gerenciada.

Tampering

- Bloquear Legacy Authentication via Conditional Access e exigir autenticação moderna.
- Monitorar sign-ins suspeitos com Identity Protection e alertas de comportamento anômalo.
- Ativar Microsoft Cloud App Security para detecção de atividades anômalas e sessões de usuários.
- Controlar compartilhamento externo (B2B) com políticas de colaboração externa e define limites de compartilhamento.
- Ativar DDoS Protection Standard para fronteiras de rede e usar Azure Front Door com WAF em endpoints de login.
- Habilitar autoscaling de serviços críticos para suportar picos de autenticação sem interrupção.
- Monitorar latência, throughput e tentativas de autenticação; acionar alertas proativos de capacidade.
- Ajustar Conditional Access para reduzir autenticação durante picos sem comprometer a usabilidade.
- Revisar regularmente permissões de Service Principal e restringir escopos de recursos.
- Aplicar just-in-time e Just-Enough Administration para tarefas administrativas críticas.

Repudiation

- Bloquear alterações sem logs de auditoria; exigir que alterações passem por trilha de mudança com aprovações.
- Implementar logs de auditoria detalhados para atividades de RBAC e políticas de acesso.
- Centralizar logs de auditoria e sign-ins no Log Analytics com retenção prolongada e exportação para SIEM externo.
- Utilizar armazenamento com imutabilidade (WORM) para logs críticos para não repudiar ações.
- Garantir trilha de auditoria confiável em ambientes com convidados e multi-tenant.

Information Disclosure

- Rotacionar credenciais de Service Principal e aplicar RBAC restritivo em recursos críticos.
- Proteger dados sensíveis com Azure Information Protection e criptografia em repouso/transporte (TDE/Always Encrypted).
- Usar Private Endpoints para APIs/Storage e reduzir exposição de dados por APIs mal protegidas.

Denial of Service

- Implementar rate-limiting e políticas de login para evitar sobrecarga de endpoints do Azure AD.

Elevation of Privilege

- Habilitar Privileged Identity Management (PIM) para elevação de privilégio com aprovação em tempo real.
- Aplicar princípio do menor privilégio com RBAC e revisões de acesso (Access Reviews) para dados sensíveis.
- Implementar Privileged Identity Management (PIM) para elevacao temporária com MFA obrigatório e janela de elevação.
- Limitar o conjunto de administradores: atribuir roles elevados apenas quando necessário e com aprovação.
- Rotacionar credenciais de contas com privilégios elevados e de Service Principal; desativar credenciais obsoletas.

Azure API Gateway

Gerado em: 2025-09-28 23:12:04

Análise STRIDE:

Tampering

- Representação (Spoofing)
- Validar JWT/OAuth 2.0 com issuer e audience no APIM.
- Exigir TLS mútuo entre APIM e backend para autenticidade de ponta a ponta.
- Validar certificados de cliente para chamadas de consumo do frontend.
- Bloquear acesso anônimo ao gateway.
- Violação de Integridade (Tampering)
- TLS 1.2+ com cipher suites restritas e validação do certificado do backend.
- Usar HTTPS para backend e, quando possível, mTLS entre APIM e backend.
- Validar integridade de payload; exigir assinatura ou validação de schema antes de transmitir.
- Verificar políticas de transformação que podem alterar dados sensíveis; evitar mudanças não autorizadas.

Repudiation

- Registrar e proteger transformações de API para auditoria.
- Habilitar logs de diagnóstico completos com correlationId.
- Enviar logs para Log Analytics/SIEM e manter retenção apropriada.
- Registrar alterações de APIs e políticas (auditoria RBAC).
- Incluir x-request-id em todas as requisições para rastreamento.
- Registrar autenticação de consumidores nas ações administrativas.
- Garantir evidência de chamadas para auditoria a longo prazo.
- Divulgação de Informação
- TLS 1.2+ end-to-end; backend com certificados válidos.
- Evitar logar dados sensíveis; aplicar redaction em logs.
- Isolar tráfego com VNet/Private Link e restrições de IP.
- Controlar cache para não expor dados sensíveis.
- Segregar ambientes e exigir autenticação forte para o portal.
- Usar Key Vault para segredos; evitar armazenamento no APIM.

Information Disclosure

- Exigir tokens emitidos por Azure AD ou IdP confiável.
- Ativar nonce/replay protection para tokens.

Denial of Service

- limitação de taxa/quota-by-key por assinatura/grupo.
- Autoescalamento do APIM e front door/WAF para DoS em camada 7.
- Circuit breaker e timeouts para backend.
- Caching estratégico para reduzir carga de backend.
- Monitoramento de picos e alertas; bloquear padrões maliciosos.
- Integrar DDoS Protection conforme necessidade.

Elevation of Privilege

- RBAC mínimo no APIM; restringir edição de políticas e APIs.
- Usar Managed Identity para acessar Key Vault; evitar segredos no APIM.
- Aprovação de mudanças de políticas e APIs; registro de alterações.
- Separação de ambientes (prod/dev) com controle de promoções.
- Dados sensíveis não expostos em logs; redação de informações.
- Restringir chamadas com OAuth2 client credentials a scopes mínimos.

Mitigações sugeridas:

Tampering

- Representação (Spoofing)
- Exigir TLS mútuo entre APIM e backend para autenticação de ponta a ponta.
- Bloquear acesso anônimo ao gateway.
- Violação de Integridade (Tampering)

Gerado em: 2025-09-28 23:12:04

- TLS 1.2+ com cipher suites restritas e validação do certificado do backend.
- Usar HTTPS para backend e, quando possível, mTLS entre APIM e backend.
- Validar integridade de payload com assinatura digital (JWS) ou validação de schema antes de transmitir.
- Verificar políticas de transformação que podem alterar dados sensíveis; evitar mudanças não autorizadas.

Repudiation

- Registrar e proteger transformações de API para auditoria com Azure monitorar/Log Analytics.
- Habilitar logs de diagnóstico completos com correlationId.
- Enviar logs para Log Analytics/SIEM e manter retenção apropriada.
- Registrar alterações de APIs e políticas (auditoria RBAC).
- Incluir x-request-id em todas as requisições para rastreamento.
- Registrar autenticação de consumidores nas ações administrativas.
- Divulgação de Informação
- TLS 1.2+ end-to-end; backend com certificados válidos.
- Redação de dados sensíveis em logs; aplicar políticas de redaction.
- Isolar tráfego com VNet/Private Link e restrições de IP.
- Controlar cache para não expor dados sensíveis.
- Segregar ambientes e exigir autenticação forte para o portal; usar Key Vault para segredos; evitar armazenamento no APIM.

Information Disclosure

- Validar JWT/OAuth tokens com issuer e audience no APIM.
- Exigir tokens emitidos por Azure AD ou IdP confiável.
- Ativar nonce/replay protection para tokens.

Denial of Service

- limitação de taxa/quota-by-key por assinatura/grupo.
- Autoescalamento do APIM e Front Door/WAF para DoS em camada 7.
- Circuit breaker e timeouts para backend.
- Caching estratégico para reduzir carga de backend.
- Monitoramento de picos e alertas; bloquear padrões maliciosos com WAF/DDoS Protection.

Elevation of Privilege

- RBAC mínimo no APIM; restringir edição de políticas e APIs.
- Usar Managed Identity para acessar Key Vault; evitar segredos no APIM.
- Aprovação de mudanças de políticas e APIs; registro de alterações.
- Separação de ambientes (prod/dev) com controle de promoções; políticas de promoção.
- Dados sensíveis não expostos em logs; redaction de logs.

API do Azure

Análise STRIDE:

Spoofing

- Credenciais de aplicação (client_id/segredos ou certificado) comprometidas permitem impersonação de Service Principal para acessar recursos no Azure.

Tampering

- Certificados de cliente usados em mTLS para acessar serviços (Key Vault, API Gateway) podem ser clonados se não houver defesa adequada.
- Dados em trânsito podem ser adulterados se TLS não for imposto ou se validação de assinatura/verificação de integridade não for aplicada entre serviços (APIM, Functions, Storage).
- Modificação de dados em Storage (Blobs, Files, Tables) ou em Cosmos DB por meio de permissões excessivas ou tokens de acesso comprometidos.
- Alteração de políticas ou configurações (APIM, Key Vault access policies) por credenciais comprometidas, mudando comportamento das APIs.

Gerado em: 2025-09-28 23:12:04

- Mensagens em filas/Service Bus/Event Grid podem ser adulteradas se permissões de envio/recebimento forem mal configuradas.
- Retenção inadequada de logs de alterações de políticas/ACLs (Key Vault, APIM, RBAC) impossibilita demonstrar quem alterou permissões.
- Acesso indevido a segredos no Key Vault devido a políticas amplas ou rotação inadequada.
- Endpoints públicos de SQL Database, Cosmos DB ou Storage com firewall mal configurado expõem dados.
- Falta de escalonamento automático para Function Apps/Logic Apps/API Management; picos de tráfego esgotam CPU/memória.
- Ataques a endpoints de autenticação/OAuth sem limitação de taxa, causando falha na autenticação sob carga.
- Modificação de políticas de acesso no Key Vault ou APIM por credenciais comprometidas, elevando permissões.

Repudiation

- Logs/telemetria podem ser adulterados para ocultar atividades (Azure monitorar, Log Analytics, Application Insights) se controles de integridade não existirem.
- Falta de logs de auditoria detalhados (autenticação/autorização) em recursos como AAD, APIM, Functions, Key Vault, dificultando atribuição de ações.
- Logs de dados de operações não vinculados por correlation IDs, dificultando reconciliação de ações.
- Logs sensíveis expostos ou mal filtrados, permitindo negação de atividades registradas.
- SAS tokens ou chaves de conta vazadas via código cliente, logs ou pipelines, resultando em divulgação de dados.

Information Disclosure

- Tokens de acesso JWT/OAuth emitidos pelo Azure AD podem ser roubados ou forjados, permitindo se passar por usuários ou serviços ao chamar APIs (API Management, Functions, App Services).
- SAS tokens de Storage ou chaves de conta vazadas possibilitam acesso não autorizado com aparência de usuário legítimo.
- Managed Identity mal configurado pode permitir obtenção de tokens por entidades não autorizadas.
- Ausência de evidências de assinatura de tokens (jti/claims) e correlação entre eventos, dificultando reconhecer quem realizou uma operação.
- Segredos (conexões, chaves, tokens) expostos em logs, telemetria ou código, levando à divulgação não autorizada.
- Dados sensíveis em trânsito não criptografados entre serviços (por exemplo, tráfego entre Function Apps e Storage) podem ser interceptados.
- Abuso de SAS tokens ou chaves com alto throughput que consomem recursos de Storage/Event Hubs.
- Credenciais de pipelines (Azure DevOps, GitHub Actions) com privilégios elevados expostas, permitindo implantação de recursos com maior nível de acesso.

Denial of Service

- Quotas mal configuradas ou sem limites, levando a limitação de taxa baixo e indisponibilidade.
- Ausência de DDoS Protection Standard para endpoints públicos, tornando-os alvos fáceis de indisponibilidade.

Elevation of Privilege

- Abuso de RBAC/Conditional Access para elevar privilégios via atribuição de roles a apps ou usuários.
- Comprometimento de Service Principal ou MSI para obter tokens com privilégios elevados e acessar recursos além do permitido.
- Privilege escalation via configurações de diretório/tenant B2B ou parcerias mal configuradas que concedem permissões extraterritoriais.

Mitigações sugeridas:

Spoofing

- Habilitar autenticação com Azure AD, MFA e Conditional Access para tokens emitidos, com validação de audience/issuer nas APIs (APIM, Functions, App Services).

Tampering

- Reduzir uso de SAS/keys; emitir SAS com expiração curta e restrições de IP, ou migrar para autenticação via Azure AD para Storage.
- Impor mTLS entre clientes e serviços com validação estrita de certificados (APIM/Service Gateway) e Private Endpoints; rotate certs.

Gerado em: 2025-09-28 23:12:04

- Forçar TLS 1.2+ e HTTPS-only em todos os serviços; aplicar HSTS em endpoints web.
- Habilitar integridade de dados com ETag/If-Match no Storage e em Cosmos DB (controle de concorrência) para detectar alterações não autorizadas.
- Restringir alterações de políticas/configs com RBAC mínimo, mudanças requerendo aprovação e registro em logs de alterações.
- Garantir proteção de filas: usar autenticação AD para Service Bus, ACLs adequadas e bloqueio de alterações não autorizadas; aplicar validação de mensagens.
- Retenção de logs de alterações de políticas/ACLs via Azure Activity Logs; exportar para armazenamento com retenção imutável.
- Fechar endpoints públicos: ativar Private Endpoints e regras de firewall para Storage/SQL/Cosmos; desativar acesso público.
- Regras para SAS/keys: evitar uso indiscriminado; rotacionar com frequência; preferir acesso via Azure AD para Storage.
- Habilitar escalonamento automático para Function Apps/Logic Apps/API Management com limites de CPU/memória.
- Ativar DDoS Protection Standard para endpoints públicos (Front Door/Azure Front Door) e distribuir tráfego com caching.
- Proteger políticas de acesso de Key Vault/APIM com RBAC e mudanças com aprovação; habilitar logging de alterações.

Repudiation

- Tornar logs imutáveis ou protegidos: usar Immutable Blob Storage/time-based retention para logs e exportar diagnósticos para storage/Log Analytics com políticas de retenção.
- Centralizar logs de autenticação/autorização (AAD Sign-ins, Audit) em Log Analytics; habilitar correlação de eventos.
- Vincular logs de operações por correlation IDs para reconciliação de ações entre serviços.
- Evitar exposição de dados sensíveis em logs: aplicar mascaramento e evitar log de payloads confidenciais.
- Evitar segredos expostos: armazenar segredos apenas no Azure Key Vault; usar Key Vault references; evitar logs de segredos; rotação regular.

Information Disclosure

- Rotacionar credenciais de aplicações (client segredos e certificados) com armazenamento seguro no Key Vault; privilegiar certificados e MSI.
- Adotar Managed Identity (system/user) com RBAC mínimo, evitando credenciais em código.
- Exigir evidência de assinatura de tokens (claims) com jti e correlação entre operações; propagar correlationId entre APIM e backend.
- Restringir acesso aos segredos no Key Vault com políticas mínimas; usar PIM para acessos privilegiados e rotação de credenciais.
- Dados em trânsito criptografados: exigir TLS 1.2+/TLS 1.3; habilitar encriptação em trânsito entre serviços (Function<->Storage) e forçar comunicação via HTTPS.
- Mitigar abuso de SAS/keys com throughput alto: restringir uso com IP allowlists, tempo de vida curto e rotação de credenciais; preferir autenticação AD.
- Imunizar Service Principal/MSI com credenciais de curto prazo; restringir recursos alocados e monitorar por anomalias; rotação regular.
- Armazenar credenciais de pipelines (DevOps/GitHub Actions) em vaults com políticas de acesso mínimo e rotação; evitar segredos em pipelines.

Denial of Service

- Definir quotas e limites de throughput por recurso (APIM, Functions, Storage) e aplicar limitação de taxa.
- Proteger endpoints de autenticação com limitação de taxa/WAF para evitar negação de serviço por autenticação.

Elevation of Privilege

- Aplicar princípio do menor privilégio com RBAC e PIM; evitar atribuições de roles privilegiadas a apps/usuários; exigir aprovação para elevação.
- Controlar acesso externo via B2B/tenant: restringir parcerias, exigir CA/consentimento de admin, usar PIM para elevação em diretório.

Gerado em: 2025-09-28 23:12:04

Azure Logic Apps

Análise STRIDE:

Spoofing

- Identidade Gerenciada (Managed Identity) nos conectores para evitar segredos estáticos.

Tampering

- Colocar API Management na frente para autenticação, verificação de assinatura e limitação de taxa.
- Exigir HTTPS/TLS 1.2 em todas as comunicações entre Logic Apps e serviços conectados.
- Validar esquemas JSON/entrada nas triggers para detectar alterações não autorizadas.
- Usar assinaturas digitais (HMAC) ou verificação de integridade em mensagens entre Logic Apps e serviços externos.
- Manter retenção de run history e exportar para armazenamento imutável para prova de execução.
- Armazenar segredos no Azure Key Vault e referenciá-los nos conectores; usar Managed Identity para acesso.
- Forçar TLS 1.2+ e HTTPS-only para todos os endpoints de dados.
- Aplicar limitação de taxa e limitação de taxa via API Management/Front Door para evitar picos de chamadas.
- Ativar Concurrency Control nos triggers para limitar execuções simultâneas.
- Configurar políticas de retry com delays exponenciais para evitar falhas repetitivas.
- Monitorar throughput e alertas no Azure monitorar para detectar abusos e automatizar bloqueios.
- Usar App Registrations com OAuth2 e certificados; rotate credentials com frequência.
- Restringir acesso aos recursos invocados pelas Logic Apps via Network Security/Private Endpoints.
- Implementar revisão de permissões e separar ambientes (Dev/Test/Prod) para manter controle de acesso.

Repudiation

- Ativar Secure inputs/outputs para evitar exposição de dados sensíveis nos logs de execução.
- Ativar logs de auditoria com diagnostics para Run History, action logs e métricas, enviando para Log Analytics/Armazenamento.
- Correlacionar execuções com logs do Azure AD para vincular ações a usuários/tokens que iniciaram a automação.
- Mascaram inputs/outputs sensíveis nos logs da run history (Secure inputs/outputs).

Information Disclosure

- Autenticação de gatilho HTTP usando OAuth2/Azure AD para restringir chamadas a tokens válidos.
- Validar o token de acesso (aud/iss) no endpoint para impedir invocação não autorizada.
- Usar assinaturas de API ou tokens com registro de chamadas para evitar negação de autoria.
- Habilitar criptografia em repouso com chaves gerenciadas (CMK) para dados sensíveis.

Elevation of Privilege

- Garantir o menor conjunto de privilégios para conectores (RBAC) e evitar funções amplas.

Mitigações sugeridas:

Tampering

- Representação (Spoofing)
- Utilizar Identity Gerenciada (Managed Identity) nos conectores para eliminar segredos estáticos.
- Colocar API Management na frente para autenticação, validação de assinatura (JWT) e limitação de taxa.
- Utilizar assinaturas digitais (HMAC) para mensagens entre Logic Apps e serviços externos.
- Violação de Integridade (Tampering)
- Validar esquemas JSON/entrada nas triggers para detectar alterações não autorizadas.
- Usar assinaturas digitais (HMAC) ou verificação de integridade em mensagens entre Logic Apps e serviços externos.
- Aplicar API Management com políticas de assinatura e validação de integridade de conteúdo.
- Referenciar segredos apenas via Azure Key Vault, evitando alterações indevidas de configuração.
- Forçar TLS 1.2+ e HTTPS-only para garantir integridade de dados em trânsito.

Repudiation

- Ativar logs de auditoria com Diagnostics para Run History, action logs e métricas, enviando para Log Analytics/Armazenamento.
- Correlacionar execuções com logs do Azure AD para vincular ações a usuários/tokens que iniciaram a automação.
- Manter retenção de run history e exportar para armazenamento imutável para prova de execução.

Gerado em: 2025-09-28 23:12:04

- Usar assinaturas de API ou tokens com registro de chamadas para evitar negação de autoria.
- Informação Confidencial (Divulgação de Informação)
- Armazenar segredos no Azure Key Vault e referenciá-los nos conectores; usar Managed Identity para acesso.
- Forçar TLS 1.2+ e HTTPS-only para todos os endpoints de dados.
- Mascaram inputs/outputs sensíveis nos logs da run history (Secure inputs/outputs).
- Habilitar criptografia em repouso com chaves gerenciadas (CMK) para dados sensíveis.
- Validar token de acesso (aud/iss) no endpoint e aplicar políticas de autenticação via API Management.

Information Disclosure

- Exigir autenticação OAuth2 com Azure AD para chamadas entre Logic Apps, conectores e serviços; token válido obrigatório.
- Validar o token de acesso (aud/iss) no endpoint antes de processar a requisição.

Denial of Service

- Aplicar limitação de taxa e limitação de taxa via API Management/Front Door para evitar picos de chamadas.
- Ativar Concurrency Control nos triggers para limitar execuções simultâneas.
- Configurar políticas de retry com delays exponenciais para evitar falhas repetitivas.
- Monitorar throughput e alertas no Azure monitorar para detectar abusos e automatizar bloqueios.
- Implementar quotas de uso por cliente em API Management para limitar consumo indevido.

Elevation of Privilege

- Garantir o menor conjunto de privilégios para conectores (RBAC) e evitar funções amplas.
- Usar App Registrations com OAuth2 e certificados; rotate credentials com frequência.
- Restringir acesso aos recursos invocados pelas Logic Apps via Private Endpoints/Network Security Groups.
- Implementar revisão de permissões e separar ambientes (Dev/Test/Prod) para manter controle de acesso.
- Utilizar Managed Identity com acessos restritos a recursos específicos para evitar credenciais estáticas.

Portal de Gerenciamento do Azure

Análise STRIDE:

Spoofing

- Sessões autenticadas podem ser sequestradas por cookies de sessão se MFA não for obrigatório para ações sensíveis.
- Identidades gerenciadas usadas por recursos comprometidos podem agir como o usuário.
- Phishing ou roubo de credenciais de admins pode levar a acesso não autorizado; exigir MFA e Conditional Access.
- Correlações entre identidades e operações podem falhar, dificultando atribuição de responsabilidade.
- Ataques a serviços de autenticação (Azure AD) podem bloquear logins administrativos; mitigação: PIM, MFA, planos de break-glass.

Tampering

- Alterações não autorizadas nas configurações de recursos via Portal podem ocorrer sem detecção se a trilha de auditoria não for robusta.
- ARM templates ou mudanças de políticas podem ser manipulados por usuários com privilégios; exigir assinatura de templates e controles de mudanças.
- Concessões de RBAC elevadas podem modificar permissões em hierarquias; usar PIM para aprovar alterações.
- Eventos críticos podem não ter assinatura de autorização, abrindo espaço para repúdio.
- Logs podem ser apagados ou alterados sem trilha de evidência confiável.
- Chaves e certificados armazenados sem proteção adequada no Key Vault podem ser acessados por entidades não autorizadas.
- Ataques a endpoints de gestão sem proteção podem esgotar recursos; mitigação: Azure Front Door/WAF, Private Link onde aplicável.
- Falha na validação de políticas pode permitir que recursos obtenham permissões indevidas; mitigação: políticas obrigatórias e controles de mudanças.

Repudiation

Gerado em: 2025-09-28 23:12:04

- Logs de diagnóstico podem ser sabotados se não houver proteção de escrita imutável; usar retenção longa e storage com imutabilidade.
- Ações administrativas podem não ser atribuídas se logs não forem imutáveis ou centralizados com verificação de integridade.
- Falta de retenção de logs de auditoria dificulta provar quem executou operações no Portal.
- segredos usados em pipelines podem vaziar em código ou logs se não houver proteção adequada.
- Dados de diagnóstico enviados para Log Analytics ou Storage podem conter informações confidenciais sem filtragem.

Information Disclosure

- Token de acesso OAuth2/JWT do Azure AD roubado pode permitir login no Portal sem senha.
- Service Principal com segredos expostos em código ou pipelines permitem autenticação indevida.
- Endpoints de gerenciamento expostos sem Private Link podem revelar detalhes de recursos e topologia.
- Tokens de sessão de admins com validade longa podem facilitar ações administrativas indevidas; mitigação: MFA, rotação de credenciais.

Denial of Service

- Sobrecarga de serviços de gerenciamento pode tornar o Portal indisponível durante picos de uso; mitigação: DDoS Protection Standard, autoscale adequado.
- Dependência de uma região para o Portal pode causar indisponibilidade; usar failover multi-região e geo-redundância.
- Configurações inadequadas de autoscale podem levar à indisponibilidade sob demanda.

Elevation of Privilege

- Azure Policy e Blueprints podem ser desativados por privilégios elevados; reforçar com bloqueio de mudanças e auditoria.
- Privilégios excessivos de RBAC permitem leitura de configs sensíveis por usuários não autorizados.
- Usuários com Owner em um resource group podem elevar privilégios alterando RBAC em camadas superiores.
- Permissões mal distribuídas em RBAC permitem escalada por meio de membros de grupos; mitigação: PIM e avaliações periódicas.
- Abusos de privilégios com contas de serviço amplas podem elevar o nível de subscrição; mitigação: segmentação de funções e revisão de permissões.

Mitigações sugeridas:

Spoofing

- Exigir MFA obrigatório via Conditional Access com avaliação de risco de sign-in.
- Usar certificados ou identidades gerenciadas em client credentials; rotacionar segredos e armazenar no Azure Key Vault.
- Correlacionar identidades e operações (Azure Sentinel/SIEM) para evidenciar responsabilidade.
- segredos em Key Vault com Access Policies; usar Identidade Gerenciada para apps; rotação de segredos.
- Rotacionar credenciais de contas de serviço/segredos; usar certificados/Identidade Gerenciada.

Tampering

- Desativar autenticação baseada em senha para usuários e apps; exigir autenticação moderna (OAuth2/OIDC) com PKCE.
- Aplicar locks de recurso (CanNotDelete/ReadOnly) em recursos críticos para impedir alterações não autorizadas.
- Exigir assinatura digital de ARM templates e mudanças via CI/CD com aprovações e gating.
- Ativar Change Tracking e Azure Activity Logs com retenção adequada; alertas de alterações.
- Bloquear mudanças de políticas com Azure Policy e Initiatives, exigindo aprovação de mudanças (Change Management).
- Private Link/Private Endpoints para endpoints de gestão; desativar endpoints públicos.
- Habilitar DDoS Protection Standard e Front Door com WAF; autoscale adequado e geo-redundância.
- Ativar failover multi-regional e disponibilidade com zone-redundancy; replicação de dados.
- Plano de resposta a incidentes e exercícios de break-glass com PIM para admin; manter runbooks atualizados.

Repudiation

- Retenção imutável de logs de auditoria (Storage com WORM/Legal Hold) e logs de diagnóstico centralizados.
- Enviar logs para Log Analytics com controle de acesso e integridade; habilitar checksums e integridade de dados.

Gerado em: 2025-09-28 23:12:04

- Habilitar trilha de evidências de ações administrativas (associar identity + timestamp) nos logs de Azure AD e Portal.
- Filtrar dados sensíveis em logs de diagnóstico (redação) e aplicar políticas de redaction.
- Controles de mudanças obrigatórios para políticas: approvals, logs e alerts.

Information Disclosure

- Implementar prova de posse (PoP) (PoP) tokens sempre que suportado, com binding a dispositivo.

Denial of Service

- Configurar limitação de taxa e quotas em APIs com API Management; uso de caching estratégico.

Elevation of Privilege

- Aplicar o menor privilégio com PIM e avaliações de acesso (Access Reviews); limitar leitura de configs sensíveis.
- Privileged Identity Management (PIM) para admins com just-in-time e aprovação; tempo limitado.
- Regras de RBAC com menor privilégio; revisões de acesso periódicas (Access Reviews).
- Segregação de funções para contas de serviço com privilégios elevados; revisar permissões.

Protocolo HTTP no Azure

Análise STRIDE:

Spoofing

- Identidades de serviço com permissões desnecessárias; revisar permissões regularmente e usar controles de acesso adequado.

Tampering

- Ausência de autenticação mútua entre serviços; adoção de mTLS com certificados gerenciados e Private Link.
- Modificação de payload em trânsito; TLS 1.2/1.3, término TLS e reencaminhamento com TLS origination.
- Alteração de conteúdo em proxies/cache; políticas de validação de assinatura (HMAC) ou API Management para validar integridade de requests.
- Manipulação de cabeçalhos ou cookies; aplicar políticas de segurança (CSP, SameSite) e validar headers no gateway.
- Não manter IDs de correlação; gerar/e manter IDs de correlação via API Management e Application Gateway.
- Dados em trânsito sem TLS; forçar HTTPS/TLS 1.2+ e habilitar HSTS.
- Segredos em configuração; migrar para Azure Key Vault com rotatividade.
- DDoS sem proteção dedicada; ativar DDoS Protection Standard.
- Sobrecarga de fronteira/serviços; usar autoscaling do Front Door/Application Gateway e CDN.
- Falta de limitação de taxa em APIs; aplicar políticas de limitação de taxa via API Management.
- Falhas de disponibilidade devido a backend não escalável; usar implantação regional, probes de saúde e failover.

Repudiation

- Dados em repouso alterados sem controle; criptografia em repouso, imutabilidade de blobs e logs de auditoria para alterações.
- Falta de logs de auditoria centralizados; habilitar Azure monitorar/Activity Logs com correlação de IDs de requisição.
- Logs passíveis de edição; ativar imutabilidade de logs (storage) e retenção apropriada em Log Analytics.
- Logs contendo dados sensíveis; redigir dados sensíveis e restringir coleta de informações.

Information Disclosure

- Roubo de tokens JWT/OAuth usados para chamadas; exigir validação de iss, aud e exp com Azure AD.
- Representação (Spoofing) de origem de chamadas por endpoints expostos; exigir TLS com Front Door/Application Gateway e verificação de domínio.
- Credenciais expostas em configuração ou código; armazenar segredos no Azure Key Vault e usar Identidade Gerenciada.
- Dados sensíveis expostos por storages públicos; desativar acesso público, usar Private Link e SAS com expiração.
- Tokens com escopos amplos permitindo ações administrativas; restringir com App Roles e políticas de acesso.
- Falha na validação de claims de token ou uso de credenciais de identidade sem verificação; reforçar validação JWT/JWKS e rotação de chaves.

Elevation of Privilege

Gerado em: 2025-09-28 23:12:04

- Ausência de evidência de operações administrativas; usar Privileged Identity Management (PIM) e sign-ins do Azure AD.
- Privilégio elevado por RBAC mal configurado; aplicar just-in-time com PIM e princípio do menor privilégio.

Mitigações sugeridas:

Spoofing

- Rotacionar chaves JWKS e validar assinatura para prevenir impersonation.
- Preferir Identidade Gerenciada em chamadas entre serviços, evitando credenciais embutidas.

Tampering

- Representação (Spoofing)
- Exigir autenticação mútua entre serviços via mTLS com certificados gerenciados e Private Link.
- TLS/DOMínio: exigir TLS com Front Door/Application Gateway e verificação de domínio confiável.
- Violação de Integridade (Tampering)
- TLS end-to-end (TLS 1.2/1.3) com terminação no edge e TLS origination para backend.
- Validar integridade de payloads com assinaturas (HMAC) ou políticas de API Management.
- Aplicar políticas de integridade em proxies/cache para impedir alteração de conteúdo.

Repudiation

- Ativar imutabilidade de dados em Storage e manter logs de auditoria para detecção de alterações.
- Centralizar logs com Azure monitorar/Activity Logs e correlacionar requisições por IDs únicos.
- Ativar imutabilidade de logs (storage) e retenção adequada no Log Analytics.
- Gerar e manter IDs de correlação via API Management e Application Gateway.
- Garantir trilha de auditoria de operações administrativas para não permitir negação de ações.
- Divulgação de Informação
- Armazenar segredos no Azure Key Vault com políticas de acesso e rotação; evitar credenciais em config/código.
- Desativar acesso público a storages; usar Private Link e SAS com expiração.
- Redigir dados sensíveis em logs e aplicar masking/redução de dados na coleta.
- Forçar TLS 1.2+ e habilitar HSTS para proteger dados em trânsito.

Information Disclosure

- Validar tokens JWT/OAuth com iss, aud e exp via Azure AD; rejeitar tokens inválidos.

Denial of Service

- Ativar DDoS Protection Standard.
- Habilitar autoscaling no Front Door/Application Gateway e CDN para picos de tráfego.
- Aplicar limitação de taxa/limitação de taxa via API Management.
- Prover implantação regional com probes de saúde e failover para continuidade.

Elevation of Privilege

- just-in-time com PIM e princípio do menor privilégio para acessos elevadores.
- Restringir tokens com escopos usando App Roles e políticas de acesso.
- Revisar regularmente permissões de identidades de serviço e remover acessos desnecessários.
- Reforçar validação de claims de token (JWT/JWKS) e rotação de chaves.

Azure Cloud Services

Análise STRIDE:

Spoofing

- Tokens de identidade roubados usados para autenticar chamadas às APIs do Azure.
- Ausência de ligação de ações a identidades em logs de management/data plane.
- Endpoints de gerenciamento expostos publicamente sem proteção de identidade/networks.
- Identidade Gerenciada mal configuradas permitem que apps acessem recursos além do necessário.

Tampering

- Integrações de SSO com IdP externos mal configuradas criam vetores de falsificação.

Gerado em: 2025-09-28 23:12:04

- Políticas de acesso condicional fracas ou desativadas não bloqueiam logins não autorizados.
- Alteração não autorizada de regras de rede (NSG/UDR) que expõem serviços.
- Dados em Storage Accounts manipulados sem integridade, sem snapshots ou imutabilidade.
- Configurações de RBAC, políticas (Azure Policy) ou recursos do Resource Manager alteradas sem registro.
- Logs/diagnóstico (Azure monitorar) modificados para ocultar atividades.
- Imagens de VMs/Containers alteradas sem verificação de assinatura/Hash.
- Storage com acesso público ativado expondo dados sensíveis.
- Registries de contêiner com permissões públicas por engano.
- Ausência de DDoS Protection Standard, expõe serviços a choques volumétricos.
- Falha de failover entre regiões; dependência de uma única região aumenta downtime.
- Endpoints sem limitação de taxa em Functions/API Apps sujeitos a abuso.
- Concessão de leitura de chaves do Key Vault para serviços indevidos; rotação insuficiente.

Repudiation

- Logs de auditoria do Azure (Activity Logs) não retidos de forma imutável dificultando atribuição de ações.
- Logs de várias origens não correlacionados entre Azure AD, Key Vault e Storage, dificultando responsabilização.
- Retenção de logs de AD e Key Vault inadequada, comprometendo auditoria.
- Mudanças críticas de políticas sem trilha de auditoria confiável.

Information Disclosure

- Credenciais comprometidas do Azure AD permitem se passar por usuário ou serviço.
- Mau uso de Service Principal com credenciais expostas em pipelines.
- segredos em Key Vault com permissões mal configuradas ou sem rotação; vazamento de segredos.
- Logs de diagnóstico não protegidos ou não criptografados, expostos.
- Credenciais embutidas em código/configurações (strings de admin) expostas em repositórios.

Denial of Service

- Autoscale mal configurado, levando à indisponibilidade em picos de tráfego.
- Quotas API/limites sem mitigação adequada, provocando falhas de serviço.

Elevation of Privilege

- RBAC excessivo (Owner/Contributor) em recursos críticos facilita elevação de privilégios.
- Segmentação inadequada entre produção/dev facilita movimentos laterais com privilégios.

Mitigações sugeridas:

Spoofing

- Tokens de identidade roubados usados para autenticar chamadas às APIs do Azure.
- Ausência de ligação de ações a identidades em logs de management/data plane.
- Endpoints de gerenciamento expostos publicamente sem proteção de identidade/networks.
- Identidade Gerenciada mal configuradas permitem que apps acessem recursos além do necessário.
- Habilitar MFA e CA para contas administrativas e serviços, com bloqueio de autenticação legada.
- Substituir segredos por certificados/Identidade Gerenciada e rotação via Key Vault.
- Garantir que ações fiquem associadas a identidades (principalId) nos registros de management/data plane.
- Exigir autenticação por identidade para endpoints de gerenciamento; usar Private Endpoints.

Tampering

- Integrações de SSO com IdP externos mal configuradas criam vetores de falsificação.
- Políticas de acesso condicional fracas ou desativadas não bloqueiam logins não autorizados.
- Alteração não autorizada de regras de rede (NSG/UDR) que expõem serviços.
- Dados em Storage Accounts manipulados sem integridade, sem snapshots ou imutabilidade.
- Configurações de RBAC, políticas (Azure Policy) ou recursos do Resource Manager alteradas sem registro.
- Logs/diagnóstico (Azure monitorar) modificados para ocultar atividades.
- Imagens de VMs/Containers alteradas sem verificação de assinatura/Hash.
- Storage com acesso público ativado expondo dados sensíveis.
- Registries de contêiner com permissões públicas por engano.
- Ausência de DDoS Protection Standard, expõe serviços a choques volumétricos.

Gerado em: 2025-09-28 23:12:04

- Falha de failover entre regiões; dependência de uma única região aumenta downtime.
- Endpoints sem limitação de taxa em Functions/API Apps sujeitos a abuso.
- Concessão de leitura de chaves do Key Vault para serviços indevidos; rotação insuficiente.
- Desativar autenticação de legado e impor políticas de acesso com risco via CA.
- Bloquear alterações não autorizadas com bloqueios de recursos (CanNotDelete/ReadOnly) em recursos críticos.
- Impor mudanças apenas via pipelines aprovadas com logs de alterações e PIM para aprovações.
- Habilitar imutabilidade de dados no Storage (Blob) com políticas de imutabilidade e snapshots.
- Exigir assinatura/validação de imagens de VM/Containers e verificação de hashes antes do deploy.
- Correlacionar eventos entre Azure AD, Key Vault e Storage via Azure monitorar/Sentinel para atribuição.
- Desativar acesso público em Storage/Key Vault; usar Private Endpoints e regras de firewall.
- Rotação de segredos no Key Vault, com políticas de acesso mínimo e purge protection.
- Garantir que registries de contêiner não tenham permissões públicas e usem acesso via IAM.
- Habilitar DDoS Protection Standard; usar Front Door/App Gateway com WAF.
- Configurar autoscale com limites seguros e testados; monitorar picos para mitigação automática.
- Configurar failover entre regiões com Traffic Manager/Front Door e replicação de dados.
- Proteger endpoints de Functions/API Apps com Private Endpoints, IP restrictions e firewalls.
- Segmentar produção e dev com arquitetura hub-and-spoke; restringir movimentos laterais.

Repudiation

- Logs de auditoria do Azure (Activity Logs) não retidos de forma imutável dificultando atribuição de ações.
- Logs de várias origens não correlacionados entre Azure AD, Key Vault e Storage, dificultando responsabilização.
- Retenção de logs de AD e Key Vault inadequada, comprometendo auditoria.
- Mudanças críticas de políticas sem trilha de auditoria confiável.
- Ativar Change Tracking e Update Management; exportar logs para storage com retenção imutável.
- Centralizar logs de auditoria (Activity Logs, Sign-in Logs, Key Vault Access Logs) em storage com retenção imutável.
- Ativar soft delete e purge protection no Key Vault; manter retenção de logs de auditoria.
- Impor trilha de auditoria para mudanças críticas de políticas com aprovações via PIM.
- Proteger logs com criptografia (CMK) e exportação para sink seguro; restringir diagnósticos.
- Restringir leitura de chaves no Key Vault via políticas de acesso; habilitar logs de acesso.

Information Disclosure

- Credenciais do Azure AD comprometidas permitem se passar por usuário ou serviço.
- Mau uso de Service Principal com credenciais expostas em pipelines.
- segredos em Key Vault com permissões mal configuradas ou sem rotação; vazamento de segredos.
- Logs de diagnóstico não protegidos ou não criptografados, expostos.
- Credenciais embutidas em código/configurações (strings de admin) expostas em repositórios.
- Rever integrações com IdP externos, exigir metadados assinados e monitoramento de tokens.
- Evitar credenciais embutidas; migrar para Key Vault e eliminar segredos no código.

Denial of Service

- Autoscale mal configurado, levando à indisponibilidade em picos de tráfego.
- Quotas API/limites sem mitigação adequada, provocando falhas de serviço.
- Aplicar quotas e limitação de taxa via API Management; bloquear abuso de endpoints.

Elevation of Privilege

- RBAC excessivo (Owner/Contributor) em recursos críticos facilita elevação de privilégios.
- Segmentação inadequada entre produção/dev facilita movimentos laterais com privilégios.
- Implementar Privileged Identity Management (PIM) para elevação just-in-time.
- Aplicar princípio de menor privilégio com RBAC; remover Owner/Contributor de recursos críticos.
- Usar PIM para elevação de privilégios com aprovação temporária.
- Monitorar elevações de privilégio com alertas no Azure monitorar/Sentinel.

Microsoft Entra ID (Azure AD)

Análise STRIDE:

Gerado em: 2025-09-28 23:12:05

Spoofing

- Autenticação MFA obrigatória com avaliação de risco (Identity Protection) para sign-ins sensíveis.
- Autenticação de aplicativos com certificados ou Identidade Gerenciada em vez de segredos, reduzindo o uso de credenciais.
- Condições de acesso baseado em risco, exigindo MFA em sign-ins de alto risco.
- Segredos de aplicativos (client segredos) ou certificados expostos em repositórios de código; mitigação: usar Azure Key Vault, rotação regular e Identidade Gerenciada.
- limitação de taxa e proteções do Azure AD acionadas por picos de sign-in; mitigação: políticas de risco, MFA para reduzir tentativas repetidas.
- Ataques de credential stuffing com contas de serviço; mitigação: MFA, sinais de risco e dispositivos em conformidade.
- Comprometimento de Global Administrator; mitigação: PIM com MFA, aprovações just-in-time e contas de alto privilégio com expiração.
- Rotação de segredos/certificados de identidade privilegiada e uso de Identidade Gerenciada para reduzir credenciais estáticas; mitigação: evitar credenciais permanentes.

Tampering

- Fluxos OAuth 2.0 com PKCE para impedir interceptação de código de autorização, especialmente para aplicações públicas.
- Modificação não autorizada de políticas de acesso condicional ou permissões via Graph por contas com privilégios; mitigação: PIM, aprovações e auditoria.
- Alteração de membros de grupos e permissões de aplicativos registrados via Graph com credenciais comprometidas; mitigação: controles de alterações, aprovação just-in-time e logs.
- Rotação de segredos de aplicativos (client segredos) e certificados; mitigação: armazenar em Key Vault, autenticação baseada em certificado e rotação regular.
- Modificação de redirect URIs de aplicativos registrados para endpoints maliciosos; mitigação: validar URIs, usar PKCE e restringir redirecionamentos.
- Ações administrativas sem trilha adequada ou sem alertas; mitigação: exigir aprovação com PIM e alertas de atividades incomuns.
- Alterações de configurações de aplicativos ou permissões registradas sem evidência de origem; mitigação: manter alterações auditáveis e ativar logs de Graph.
- Redirect URIs inadequados ou conexões não seguras (HTTP); mitigação: exigir HTTPS, validar URIs e restringir endpoints.
- Inundação de chamadas a Graph API para alterações de diretório; mitigação: respeitar limites, implementar backoff exponencial e caching.

Repudiation

- Logs de auditoria e sign-in não retidos pela duração necessária; mitigação: configurar retenção adequada e exportar para SIEM/monitores.
- Mudanças em membros de grupos com evidência de auditoria; mitigação: retenção de logs e monitoramento.
- Dados sensíveis em logs de sign-in ou auditoria; mitigação: mascarar dados sensíveis e restringir acesso aos logs.
- Gerenciamento de privilégios via Privileged Identity Management (PIM) com aprovações; mitigação: exigir aprovação, rotação de credenciais e logs de atividades.

Information Disclosure

- Autenticação sem senha via FIDO2/WebAuthn e Windows Hello for Business para evitar credenciais roubadas.
- Modificação de claims mapeadas ou configuração de emissão de tokens; mitigação: minimizar claims expostos e revisar configurações de emissão.
- Exposição de dados de usuários e grupos por APIs Graph com permissões excessivas; mitigação: aplicar princípio do menor privilégio e revisões de permissões de aplicativo.
- Tokens de acesso/ID expostos por armazenamento inseguro no lado do cliente; mitigação: armazenamento seguro, PKCE e evitar armazenamento de tokens sensíveis.
- Grupos de acesso privilegiado (PAG) com membros expostos a abuso; mitigação: aprovações, just-in-time e políticas de expiração.

Denial of Service

Gerado em: 2025-09-28 23:12:05

- Configurações de Conditional Access mal testadas que bloqueiam usuários legítimos, causando indisponibilidade; mitigação: testar em ambientes de staging antes do rollout.

Elevation of Privilege

- Aplicações com permissões elevadas (Application Permissions) usadas por atacantes para modificar recursos; mitigação: mínimo privilégio, revisão de consentimento e autenticação baseada em certificado.

Mitigações sugeridas:

Spoofing

- MFA com avaliação de risco para sign-ins sensíveis via Identity Protection.
- Autenticação de aplicativos com certificados ou Identidade Gerenciada em vez de segredos.
- Condições de Acesso com base em risco exigindo MFA em sign-ins de alto risco.

Tampering

- Falsificação (Representação (Spoofing))
- Autenticação passwordless com FIDO2/WebAuthn e Windows Hello for Business.
- Fluxos OAuth 2.0 com PKCE para aplicações públicas.
- Modificação (Violação de Integridade (Tampering))
- Controles de mudança com aprovação just-in-time para alterações de políticas de acesso condicional e permissões via Graph; logs persistentes.
- Rotação de segredos e certificados de aplicativos com Key Vault e autenticação baseada em certificado.
- Validação de redirect URIs de aplicativos registrados para evitar endpoints maliciosos; políticas PKCE e restrição de redirecionamento.

Repudiation

- Aprovação e auditoria para mudanças de membros de grupos e de aplicações registradas via Graph (credenciais comprometidas).
- Retenção de logs de auditoria/sign-ins pelo tempo necessário; exportação para SIEM/monitores.
- Aprovação com PIM para ações administrativas sensíveis e alertas de atividades incomuns.
- Habilitar logs de Graph para alterações de configurações de aplicativos/permissões com evidência de origem.
- Registro e monitoramento de mudanças em membros de grupos com evidência de auditoria.
- Divulgação de Informação (Divulgação de Informação)
- Princípio do menor privilégio aplicado às APIs Graph; revisões periódicas de permissões de aplicativos.
- Segredos de aplicativos ou certificados expostos em repositórios: armazenar em Azure Key Vault, rotação regular e uso de Identidade Gerenciada.
- Tokens de acesso/ID expostos por armazenamento inseguro no cliente: PKCE, armazenamento seguro e evitar tokens sensíveis.
- Dados sensíveis em logs: mascarar dados sensíveis e restringir acesso aos logs.
- Redirect URIs inadequados: exigir HTTPS, validar URIs e restringir endpoints.

Information Disclosure

- Minimizar claims expostos e revisar configurações de emissão de tokens (emissor/claims).

Denial of Service

- Políticas de risco e MFA para reduzir tentativas repetidas em sign-ins.
- Testes de Conditional Access em ambientes de staging para evitar bloqueios de usuários legítimos.
- Respeitar limites do Graph API, com backoff exponencial e caching.
- MFA, sinais de risco e dispositivos em conformidade para reduzir ataques de credential stuffing em contas de serviço.
- Elevação de Privilégios (Elevação de Privilégio)
- Privileged Identity Management (PIM) com MFA, aprovações just-in-time e expiração de contas de alto privilégio.
- Aplicações com permissões elevadas (Application Permissions) devem usar mínimo privilégio, revisão de consentimento e autenticação baseada em certificado.
- Rotação de credenciais de identidade privilegiada e uso de Identidade Gerenciada para reduzir credenciais estáticas; manter logs de atividades.
- Grupos de acesso privilegiado (PAG) com aprovações just-in-time e políticas de expiração.

Gerado em: 2025-09-28 23:12:05

- Princípio do menor privilégio para gerenciamento de privilégios; rastrear atividades com logs e alertas de atividades incomuns.